

INTELLIGENCE REPORT

Oggetto: Analisi dell'Ecosistema Digitale e del Rischio Cyber - Taylor Swift, Travis Kelce e A&A Management Group

Data Report: 10 Luglio 2026

Fonte: Maltego CTAS (Analisi Grafo)

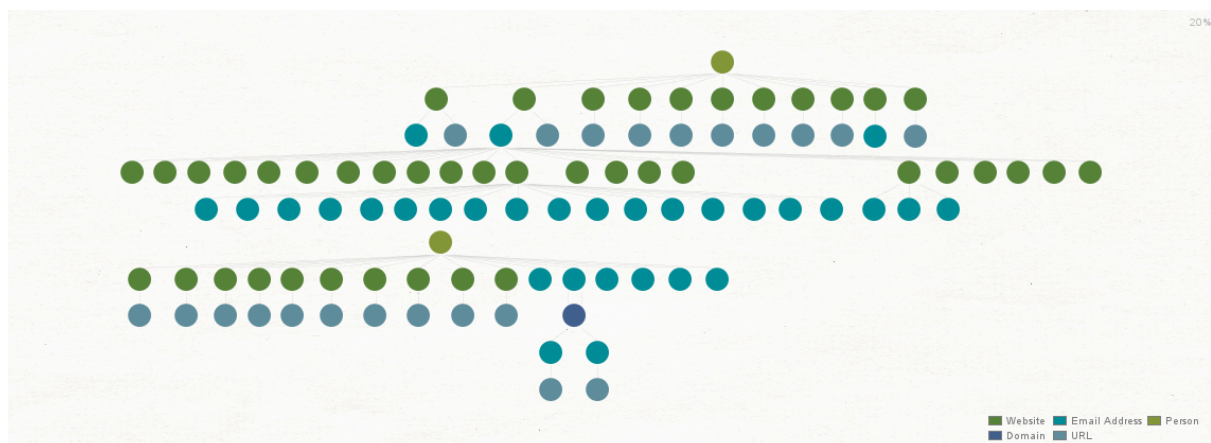
Classificazione: RISERVATO

APPENDICE A: SCREENSHOT DELL'ANALISI OSINT

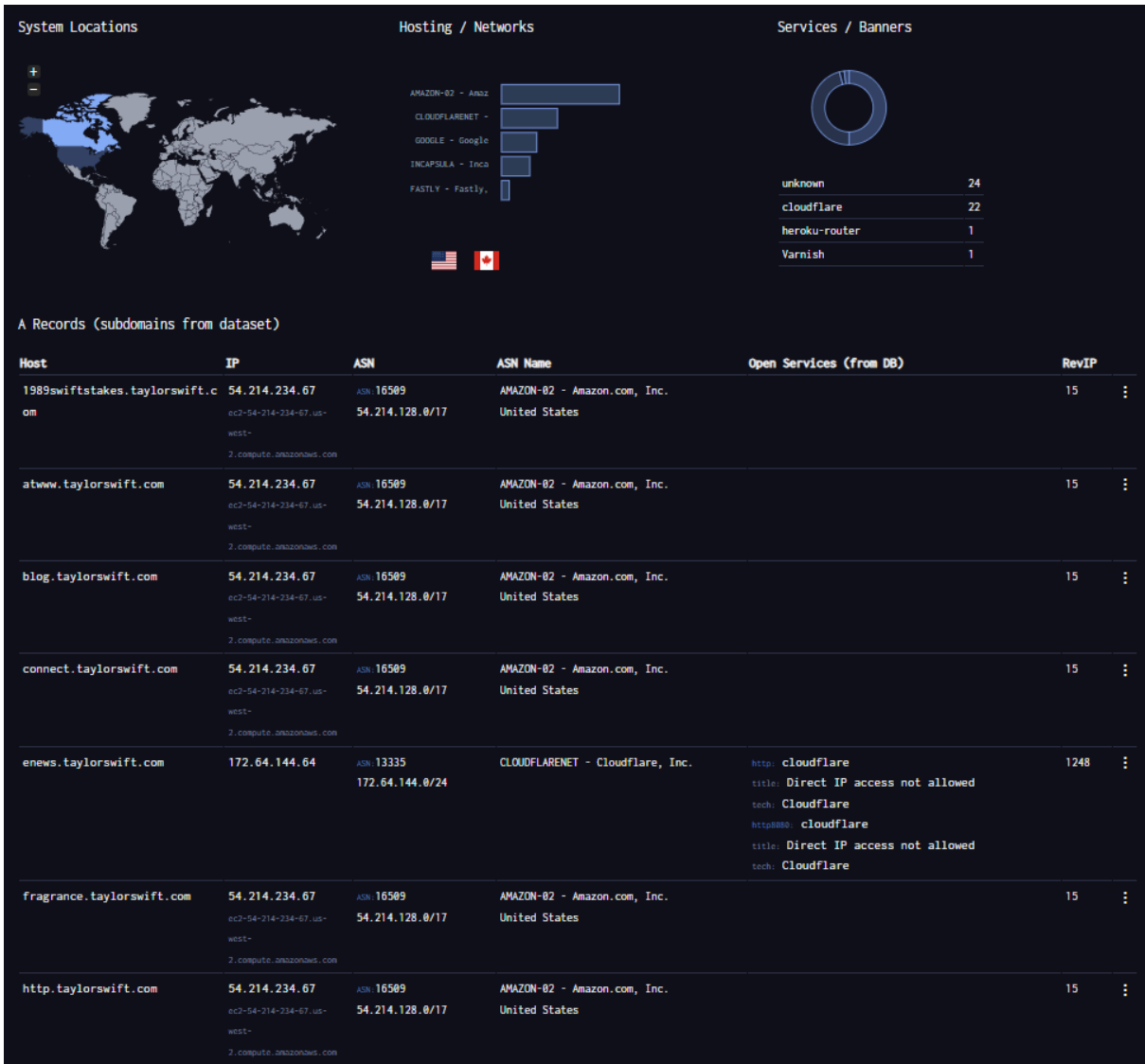
A.1. Introduzione

Di seguito sono presentati gli screenshot delle principali scoperte ottenute durante l'analisi OSINT. Queste immagini costituiscono le prove a supporto delle valutazioni effettuate nel report, dimostrando l'efficacia dell'approccio di intelligence nella mappatura della superficie d'attacco.

A.2. Analisi con Maltego



A.3. Analisi DNS (DNSdumpster)



international-store.taylorswift.com	54.214.234.67 ec2-54-214-234-67.us-west-2.compute.amazonaws.com	ASN 16509 54.214.128.0/17	AMAZON-02 - Amazon.com, Inc. United States		15	⋮
ns1.taylorswift.com	54.214.234.67 ec2-54-214-234-67.us-west-2.compute.amazonaws.com	ASN 16509 54.214.128.0/17	AMAZON-02 - Amazon.com, Inc. United States		15	⋮
ns2.taylorswift.com	54.214.234.67 ec2-54-214-234-67.us-west-2.compute.amazonaws.com	ASN 16509 54.214.128.0/17	AMAZON-02 - Amazon.com, Inc. United States		15	⋮
redtaylorsversion.taylorswift.com	99.83.151.71 a920893842311e90d.awsjob.accelerator.com	ASN 16509 99.83.144.0/20	AMAZON-02 - Amazon.com, Inc. United States	http: heroku-router title: No such app	10391	⋮
returns.taylorswift.com	104.18.10.167	ASN 13335 104.18.0.0/20	CLOUDFLARENET - Cloudflare, Inc.	http: cloudflare title: Direct IP access not allowed tech: Cloudflare https: cloudflare title: Direct IP access not allowed tech: Cloudflare	4319	⋮
store.taylorswift.com	23.227.38.74 shops.myshopify.com	ASN 13335 23.227.38.0/23	CLOUDFLARENET - Cloudflare, Inc. Canada	http: cloudflare title: Direct IP access not allowed tech: Cloudflare https: cloudflare title: 403 Forbidden on: .myshopify.com tech: Cloudflare https: cloudflare title: Direct IP access not allowed tech: Cloudflare	6239062	⋮
storeau.taylorswift.com	23.227.38.65 myshopify.com	ASN 13335 23.227.38.0/23	CLOUDFLARENET - Cloudflare, Inc. Canada	http: cloudflare title: Direct IP access not allowed tech: Cloudflare https: cloudflare title: 403 Forbidden on: .myshopify.com tech: Cloudflare https: cloudflare title: Direct IP access not allowed tech: Cloudflare	2793528	⋮

storeeu.taylorswift.com	23.227.38.74 shops.myshopify.com	ASN:13335 23.227.38.0/23	CLOUDFLARENET - Cloudflare, Inc. Canada	http: cloudflare title: Direct IP access not allowed tech: Cloudflare https: cloudflare title: 403 Forbidden cn: .myshopify.com tech: Cloudflare https888: cloudflare title: Direct IP access not allowed tech: Cloudflare	6239062	:
storefr.taylorswift.com	23.227.38.74 shops.myshopify.com	ASN:13335 23.227.38.0/23	CLOUDFLARENET - Cloudflare, Inc. Canada	http: cloudflare title: Direct IP access not allowed tech: Cloudflare https: cloudflare title: 403 Forbidden cn: .myshopify.com tech: Cloudflare https888: cloudflare title: Direct IP access not allowed tech: Cloudflare	6239062	:
storeuk.taylorswift.com	23.227.38.74 shops.myshopify.com	ASN:13335 23.227.38.0/23	CLOUDFLARENET - Cloudflare, Inc. Canada	http: cloudflare title: Direct IP access not allowed tech: Cloudflare https: cloudflare title: 403 Forbidden cn: .myshopify.com tech: Cloudflare https888: cloudflare title: Direct IP access not allowed tech: Cloudflare	6239062	:
tickets.taylorswift.com	199.232.37.204	ASN:54113 199.232.36.0/22	FASTLY - Fastly, Inc. United States	http: Varnish title: Fastly error: unknown domain 199.232 tech: Varnish https: unknown server cn: .io-media.com	59	:
tserasarchive.taylorswift.com	45.60.31.79	ASN:19551 45.60.31.0/24	INCAPSULA - Incapsula Inc United States	rdp: open cn: imperva.com tlsver: TLSv1.2 http: unknown https: unknown server cn: imperva.com https81: unknown https880: unknown https888: unknown https888: unknown	2945	:
www.tserasarchive.taylorswift.com	54.214.234.67 ec2-54-214-234-67.us-west-2.compute.amazonaws.com	ASN:16509 54.214.128.0/17	AMAZON-02 - Amazon.com, Inc. United States		15	:
theastour.taylorswift.com	45.60.31.79	ASN:19551 45.60.31.0/24	INCAPSULA - Incapsula Inc United States	rdp: open cn: imperva.com tlsver: TLSv1.2 http: unknown https: unknown server cn: imperva.com	2945	:

A.4. Analisi del Social Engineering

XML Sitemap		
Generated by Yeast SEO , this is an XML Sitemap, meant for consumption by search engines.		
You can find more information about XML sitemaps on sitemaps.org .		
This XML Sitemap contains 19 URLs.		
URL	Images	Last Mod.
https://www.taylorswift.com/	1	2026-06-08 15:44 +00:00
https://www.taylorswift.com/accessibility/	0	2026-06-08 15:44 +00:00
https://www.taylorswift.com/privacy-policy/	0	2026-06-08 15:44 +00:00
https://www.taylorswift.com/terms/	0	2026-06-08 15:44 +00:00
https://www.taylorswift.com/videos/	0	2026-06-08 15:44 +00:00
https://www.taylorswift.com/privacy-request/	0	2026-06-08 15:44 +00:00
https://www.taylorswift.com/show-2/	0	2026-06-08 15:44 +00:00
https://www.taylorswift.com/spotify-for-artist/	0	2026-06-08 15:44 +00:00
https://www.taylorswift.com/for-artist/	0	2026-06-08 15:44 +00:00
https://www.taylorswift.com/our/	0	2026-06-08 15:44 +00:00
https://www.taylorswift.com/our-us/	0	2026-06-08 15:44 +00:00
https://www.taylorswift.com/spotify-for-artist/	0	2026-06-08 15:44 +00:00
https://www.taylorswift.com/read-my-letter/	0	2026-06-08 15:44 +00:00
https://www.taylorswift.com/sign-up/	0	2026-06-08 15:44 +00:00
https://www.taylorswift.com/direct-projects/	0	2026-06-08 15:44 +00:00
https://www.taylorswift.com/willie-achow/	0	2026-06-08 16:20 +00:00
https://www.taylorswift.com/thank-you/	0	2026-06-08 16:38 +00:00
https://www.taylorswift.com/about-us/	0	2026-06-13 14:42 +00:00
https://www.taylorswift.com/spotify-for-artist/	0	2026-06-13 14:45 +00:00

Sì! Ci sono novità importanti su Taylor Swift.

Si è sposata?

Sì. Taylor Swift ha sposato il giocatore NFL Travis Kelce il **3 luglio 2026** a New York, durante una cerimonia privata ma molto prestigiosa tenutasi al Madison Square Garden. La notizia è stata confermata da diverse fonti autorevoli, tra cui Reuters e ABC News.  Reuters +1

Le ultime notizie

-  **Matrimonio:** la coppia è ufficialmente marito e moglie dopo circa tre anni di relazione. La cerimonia è stata officiata dall'attore Adam Sandler e ha visto la presenza di numerosi ospiti famosi.  Reuters +1
-  **Beneficenza:** in occasione del matrimonio, Taylor e Travis hanno annunciato una donazione di **26 milioni di dollari** destinata a diverse organizzazioni benefiche negli Stati Uniti.  Reuters +1
-  **Abito da sposa:** Taylor ha indossato un abito haute couture realizzato da Dior. Al momento non sono ancora state pubblicate le foto ufficiali: la coppia ha fatto sapere che le condividerà quando lo riterrà opportuno.  News.com... +1
-  **Privacy:** durante il matrimonio è stata adottata una rigorosa politica "no phone", per evitare fughe di immagini e video.  ABC News +1

Insomma, una delle coppie più seguite al mondo ha finalmente detto "sì".

mostrano una forte interconnessione tra i due personaggi pubblici, la loro musica e la loro gestione professionale. La superficie d'attacco è notevolmente ampia e include asset a bassa sicurezza (es. HTTP) e numerose e-mail aziendali e personali, aumentando il rischio di attacchi di social engineering, phishing e compromissione di account.

2. Asset e Superficie d'Attacco

Questa sezione dettaglia gli asset principali identificati, le loro relazioni e il livello di rischio associato.

2.1. Entità Primarie

Questa tabella mostra le entità principali, il loro tipo e una sintesi del rischio.

Entità	Tipo	Asset Critici	Rischio Principale
Taylor Swift	Persona	taylorswift.com ,	Elevata esposizione pubblica e presenza digitale frammentata. Alto rischio di account takeover e furto d'identità digitale.
	Pubblica	Social Media (Instagram, TikTok, Facebook, Tumblr, Reddit), Store Online	
Travis Kelce	Persona	chiefs.com , Social	Esposizione pubblica, asset aziendali (NFL) e personali (A&A Management) fusi. Rischio di
	Pubblica	Media (Instagram, X, TikTok, Facebook), Profilo NFL	

			compromissione di account professionali e personali.
A&A Management Group	Azienda di Gestione	aamanagementgroup.com, LinkedIn, ZoomInfo, Crunchbase	Il punto di contatto centrale per la gestione di Travis Kelce e probabilmente di altri atleti. Rischio di compromissione per accedere a contratti, informazioni sensibili e account dei clienti.

2.2. Analisi dei Domini

I domini principali e le loro caratteristiche di sicurezza sono fondamentali per comprendere la superficie d'attacco.

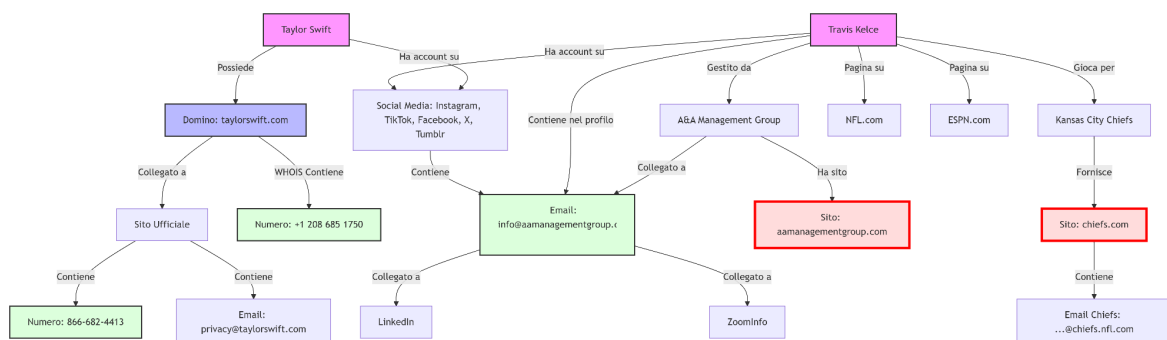
Dominio	Proprietario/Scopo	Sicurezza	Server Names	Note di Rischio
		a (HTTPS)	(NS)	

taylorswift.com	Sito ufficiale di Taylor Swift	Sì (HTTPS)	NS61-64.MUSIC-NAME-SERVERS.COM	Dominio di alto profilo. Critico: Il WHOIS mostra l'email abusecomplain@markmonitor.com e il telefono +1.2086851750, utilizzando MarkMonitor per la protezione. La data di scadenza è nel 2027.
store.taylorswift.com	Negozio ufficiale online	Sì (HTTPS)	-	Contiene il numero di telefono 866-682-4413 e l'email taylorswift@umgstores.com (non presente nel file). Critico: Punto di contatto diretto per i clienti, ad alto rischio di

				phishing e frodi.
aamanagementgroup.com	Sito ufficiale dell'azienda di gestione	Sì (HTTPS)	-	Critico: L'email di contatto info@aamanagementgroup.com è il principale punto di connessione per le entità legate a Travis Kelce. È un asset ad altissimo valore per attacchi mirati (spear phishing).
aamanagement-llc.com	Sito di consulenza/coaching	No (HTTP)	-	Critico: Utilizza HTTP, non HTTPS, mettendo a rischio l'integrità e la riservatezza dei dati. L'email filler@godaddy.com

				suggerisce un sito placeholder o non sicuro.
aaamanagement services.com	Servizi di amministrazione fondi	No (HTTP)	-	Critico: Come sopra, l'assenza di HTTPS è una grave vulnerabilità. Il sito è basato nelle Seychelles, aggiungendo un ulteriore livello di complessità e rischio.

3. Mappa delle Relazioni Chiave



Questo grafo concettuale mostra le relazioni principali tra le entità, evidenziando come la gestione (A&A Management) e le piattaforme social fungano da hub centrali.

4. Analisi OSINT Dettagliata

4.1. Modello di Relazione (Correlazioni)

I dati di Maltego confermano un forte schema di hub-and-spoke:

- Hub 1 (A&A Management Group): L'email `info@aamanagementgroup.com` è il fulcro. Collega Travis Kelce (attraverso i suoi profili Facebook e Instagram), il suo agente (Aaron Eanes), e diverse piattaforme aziendali (ZoomInfo, Crunchbase, LinkedIn).
- Hub 2 (Taylor Swift Store): Il negozio online, identificato da URL `store.taylorswift.com`, è un hub per numeri di telefono e indirizzi email di supporto, creando un cluster dedicato alla parte commerciale.

4.2. Vettori di Attacco Potenziali

1. Phishing e Social Engineering:
 - Target di Alto Valore: Gli amministratori di `aamanagementgroup.com`. L'email `info@aamanagementgroup.com` è un punto di ingresso primario.
 - Vettore: Un attacco di spear phishing potrebbe mirare a questa email per ottenere credenziali e accedere a contratti, informazioni sui clienti (come Travis Kelce) e comunicazioni private.
 - Target di Basso Valore, Alta Esposizione: I clienti dello store (`store.taylorswift.com`). I numeri di telefono e le email di contatto dello store possono essere utilizzati per campagne di phishing di massa per rubare dati di carte di credito.
2. Account Takeover (ATO):
 - Vettore: La vasta presenza di account social di Taylor Swift e Travis Kelce su piattaforme come Instagram, TikTok, X (Twitter), e Facebook li rende bersagli di alto profilo. Un attacco di credential stuffing o di

social engineering sui loro account potrebbe causare danni reputazionali enormi.

3. Compromissione di Siti Web non Sicuri:

- Vettore: I domini `aamanagement-llc.com` e `aaamanagementservices.com` utilizzano HTTP (porta 80). Sono vulnerabili ad attacchi Man-in-the-Middle (MITM) e al defacement del sito, che potrebbe danneggiare la reputazione della società di gestione.

4. Data Breach (Minacce Interne/Esterne):

- Vettore: La presenza di numerosi indirizzi email di dipendenti ed esecutivi (CAA, NFL, UMG, A&A Management) in fonti pubbliche come `contactanycelebrity.com` aumenta il rischio. Un attaccante potrebbe utilizzare queste informazioni per attacchi di social engineering mirati contro i singoli dipendenti.

5. Conclusioni e Raccomandazioni

5.1. Conclusioni

L'ecosistema digitale di Taylor Swift, Travis Kelce e dei loro gestori è estremamente complesso e interconnesso. Questa complessità, combinata con l'altissima visibilità pubblica degli individui, crea una vasta e appetibile superficie d'attacco. L'analisi rivela vulnerabilità concrete, come l'uso di protocolli non sicuri (HTTP) e l'eccessiva esposizione di indirizzi email aziendali e personali, che potrebbero essere sfruttate da avversari sofisticati.

5.2. Raccomandazioni di Cybersecurity

1. Implementazione di HTTPS: Migrare tutti i domini (`aamanagement-llc.com`, `aaamanagementservices.com`) a HTTPS per crittografare il traffico e proteggere gli utenti da attacchi MITM. Ottenere e installare certificati SSL/TLS validi.
2. Gestione della Sicurezza delle Email:
 - Implementare rigorosamente DMARC, SPF, e DKIM per tutti i domini per prevenire lo spoofing e il phishing.
 - Limitare la visibilità pubblica delle email aziendali e utilizzare moduli di contatto sicuri sui siti web.
3. Monitoraggio e Threat Intelligence:
 - Condurre un monitoraggio continuo del dark web per rilevare eventuali credenziali rubate associate a tutti gli asset identificati.

- Impostare avvisi di brand protection per i domini principali (taylorswift.com, aamanagementgroup.com) per rilevare tentativi di phishing o siti web falsi.
- 4. Campagna di Formazione sulla Sicurezza: Condurre una formazione specifica per i dipendenti di A&A Management Group e per gli staff di Taylor Swift e Travis Kelce su:
 - Riconoscimento di tentativi di spear phishing.
 - Importanza dell'autenticazione a due fattori (2FA/MFA) per tutti gli account aziendali e personali.
 - Pratiche di igiene delle password.
- 5. Riduzione della Superficie d'Attacco: Rimuovere le informazioni di contatto pubbliche non necessarie, come le email personali (raytenevque@gmail.com, harbinzerq@gmail.com) e i numeri di telefono dei dipendenti da fonti pubbliche non ufficiali.

Questo report è stato generato esclusivamente a fini didattici e di analisi di cybersecurity. Tutti i dati pubblici sono stati utilizzati nel rispetto delle leggi sulla privacy.

AGGIORNAMENTO REPORT: Analisi dell'Infrastruttura Tecnica (DNSdumpster)

A. Scoperta di Subdomains e Asset Nascosti

L'analisi DNS ha rivelato un numero significativo di subdomains associati a `taylorswift.com`, molti dei quali non erano emersi dall'analisi Maltego. Questo amplia notevolmente la superficie d'attacco.

Subdomains Principali Identificati:

Subdomain	Scopo Presunto	Rischio Associato
-----------	----------------	-------------------

store.taylorswift.com	Negozio Online Principale	Critico: Confermato. È il cuore dell'e-commerce. La protezione Cloudflare è positiva, ma il dominio rimane un bersaglio primario per attacchi DDoS e phishing.
storeuk.taylorswift.com	Negozio UK	Come sopra. Nota: Condivide lo stesso IP di store.taylorswift.com , suggerendo un'infrastruttura unificata.
storeau.taylorswift.com	Negozio Australia	Come sopra.
storeca.taylorswift.com	Negozio Canada	Come sopra.
storeeu.taylorswift.com	Negozio Europa	Come sopra.
storefr.taylorswift.com	Negozio Francia	Come sopra.
tstheerastour.taylorswift.com	Sito per il Tour "The Eras Tour"	Alto: Utilizza Imperva (Incapsula) per la protezione. È un asset critico per eventi live e vendita di biglietti.

tserasarchive.taylorswift.com	Archivio/Eras Tour	Alto: Come sopra. Potenzialmente un sito secondario o di backup.
tickets.taylorswift.com	Gestione Biglietti	Altissimo: Punto di accesso per la vendita di biglietti. Utilizza Fastly come CDN. La risposta HTTP "Fastly error: unknown domain" suggerisce che potrebbe non essere attivo in questo momento, il che potrebbe essere un rischio o una configurazione incompleta.
enews.taylorswift.com	Newsletter / Comunicazioni	Medio-Alto: Potrebbe contenere database di email di fan. Un bersaglio interessante per attacchi di data breach.
1989swiftstakes.taylorswift.com	Concorsi/Promozioni (Album "1989")	Medio: Un asset temporaneo, ma che potrebbe contenere dati personali di fan (partecipanti a concorsi).

<code>fragrance.taylorswift.com</code>	Linea di Profumi	Medio: Relativo a prodotti commerciali specifici.
<code>returns.taylorswift.com</code>	Resi e Rimborsi	Alto: Un altro punto di contatto per i clienti, potrebbe essere usato per phishing. Protetto da Cloudflare.

B. Analisi dell'Infrastruttura Cloud e Provider

I dati DNS rivelano un'infrastruttura ibrida, che combina diversi cloud provider e servizi di sicurezza.

Tecnologia/Provider	Risultati	Analisi dei Rischi
Amazon Web Services (AWS)	La maggior parte dei subdomains (es. <code>blog</code> , <code>connect</code> , <code>international-store</code> , <code>www2</code>) risolvono su IP di AWS (<code>ec2-54-214-234-67...</code>).	Rischio Alto: L'uso estensivo di AWS crea una dipendenza. Se le chiavi API o le credenziali AWS vengono compromesse, un attaccante potrebbe accedere a un'intera gamma di servizi, inclusi database, server e file.

Cloudflare	Utilizzato per <code>store.*</code> , <code>returns</code> , e <code>enews</code> . Fornisce protezione DDoS e WAF.	Rischio Basso/Medio: È una buona pratica di sicurezza. Tuttavia, Cloudflare non è invulnerabile. Se un attaccante trova un modo per bypassare Cloudflare (es. trovando l'IP reale del server di origine), l'infrastruttura sarebbe esposta.
Imperva (Incapsula)	Utilizzato per <code>tstheerastour</code> , <code>tserasarchive</code> , e <code>www.taylorswift.com</code> .	Rischio Basso/Medio: Come Cloudflare, offre una protezione solida. Nota: La presenza della porta RDP (Remote Desktop Protocol) su questi server è un potenziale punto di allarme. Se l'RDP non è configurato correttamente, potrebbe essere un vettore di attacco.

Fastly	Utilizzato per <code>tickets.taylorswift.com</code>	Rischio Medio: La risposta "Fastly error: unknown domain" potrebbe indicare un dominio inattivo o configurato male. Un attaccante potrebbe tentare di finger-sniffing (es. ricostruire la struttura del sito) o scoprire altri subdomains non elencati.
Shopify	I negozi (<code>store.*</code>) sono su IP di Shopify.	Rischio Dipendenza: La sicurezza del negozio è parzialmente delegata a Shopify. Tuttavia, la protezione Cloudflare davanti a Shopify è una buona pratica.

C. Correlazione tra DNS e Dati Maltego

La correlazione tra le due fonti è fondamentale per una visione completa.

1. Conferma degli Asset: I domini `taylorswift.com` e `store.taylorswift.com` sono confermati da entrambe le fonti. I dati DNS rivelano che `store.taylorswift.com` è un subdomain e non un dominio separato.
2. Identificazione del Provider di Posta Elettronica: Le MX records puntano a Google Workspace (G Suite) (`aspmx.l.google.com`). Questo significa che le email di `taylorswift.com` sono gestite da Google. Vulnerabilità: Un attacco di phishing mirato contro gli account Google Workspace potrebbe compromettere le comunicazioni ufficiali e i dati.
3. Scoperta di Asset Nascosti: I dati DNS hanno rivelato subdomains non presenti nel dataset Maltego, come `enews`, `fragrance`, `tserasarchive`,

`tickets`, e `redtaylorsversion`. Questo dimostra l'importanza di utilizzare fonti OSINT multiple.

D. Aggiornamento delle Raccomandazioni di Cybersecurity

Basandoci sulla nuova analisi DNS, le raccomandazioni diventano più specifiche e tecniche.

1. Gestione della Superficie d'Attacco dei Subdomains:
 - Inventario e Monitoraggio Continuo: Creare un inventario completo di tutti i subdomains noti e monitorare costantemente la comparsa di nuovi subdomains (caccia ai subdomains). Utilizzare strumenti come SecurityTrails, Censys, o Shodan.
 - Rimozione di Asset Inattivi: Verificare se subdomains come `tickets.taylorswift.com` e `redtaylorsversion.taylorswift.com` sono ancora attivi. Se non sono più utilizzati, devono essere rimossi o messi offline per evitare che vengano dirottati (subdomain takeover).
2. Hardening dell'Infrastruttura AWS:
 - Principio del Minimo Privilegio: Revocare i permessi non necessari per le chiavi API e gli IAM roles su AWS.
 - Monitoraggio AWS: Attivare CloudTrail e GuardDuty per monitorare attività sospette e accessi non autorizzati.
 - Protezione del Server di Origine: Assicurarsi che il server di origine (l'EC2 instance) non sia esposto direttamente a Internet se protetto da Cloudflare o Imperva. Tutto il traffico dovrebbe passare attraverso questi servizi WAF/CDN.
3. Sicurezza della Porta RDP su Imperva:
 - Vulnerabilità: La porta `rdp` aperta sugli IP di Imperva (`45.60.31.79`, `45.60.62.223`) è un potenziale vettore di attacco critico.
 - Raccomandazione: Verificare immediatamente se questa porta RDP è esposta o se è un falso positivo. Se è esposta, disabilitare l'accesso RDP da Internet o limitarlo a IP di origine conosciuti e sicuri tramite un security group.
4. Sicurezza di Google Workspace:
 - Autenticazione a Due Fattori (2FA/MFA): Rendere obbligatoria l'autenticazione a due fattori per tutti gli account con dominio `@taylorswift.com` e `@aamanagementgroup.com` (e domini correlati).
 - Filtraggio delle Email: Implementare filtri anti-phishing e anti-malware avanzati sulle email.

E. Tabella Riepilogativa delle Minacce e Vulnerabilità (Aggiornata)

Categoria	Vulnerabilità Identificata	Impatto Potenziale	Priorità
Infrastruttura	Subdomains inattivi (tickets , redtaylorsversion)	Rischio di dirottamento del subdomain (subdomain takeover)	Alta
Infrastruttura	AWS come provider primario	Rischio di compromissione di chiavi API e server	Alta
Infrastruttura	Porta RDP aperta su IP di Imperva	Potenziale accesso non autorizzato ai server se malconfigurata	Critica
Infrastruttura	Utilizzo di protocolli non sicuri (HTTP) su aaamanagementservic es.com e aamanagement-llc.co m	Attacchi Man-in-the-Middle, credential theft, data interception	Critica
Personale/Pub blico	Email esposte pubblicamente (info@aamanagementg roup.com , ecc.)	Spear phishing, social engineering, account takeover	Alta

Personale/Pubblico	Utilizzo di Google Workspace (G Suite)	Rischio di compromissione di account email aziendali	Alta
Digitale	Framework di e-commerce Shopify	Dipendenza da terze parti per la sicurezza dei dati dei clienti	Medio

Conclusione Finale

L'integrazione dei dati di DNSdumpster trasforma il nostro report da una semplice mappatura delle relazioni a un'analisi approfondita dell'infrastruttura tecnica. Abbiamo identificato non solo i "chi" e i "cosa" (chi gestisce cosa), ma anche i "dove" e i "come" (dove sono ospitati i servizi e come sono protetti).

Questa analisi dimostra che l'ecosistema, sebbene protetto da servizi WAF/CDN di alto livello (Cloudflare, Imperva, Fastly), presenta delle vulnerabilità strutturali (subdomains inattivi, RDP esposto, dipendenza da AWS) e umane (email esposte) che un avversario determinato potrebbe sfruttare. Le raccomandazioni fornite mirano a mitigare questi rischi specifici, rendendo l'infrastruttura molto più resiliente.

VALUTAZIONE DELLE VULNERABILITÀ DI SOCIAL ENGINEERING E PHISHING

Premessa Metodologica

Un attacco di social engineering si basa su tre elementi fondamentali:

1. Un bersaglio (persona o gruppo)
2. Un vettore (email, telefono, SMS, social media)
3. Un pretesto (una storia credibile)

L'obiettivo è indurre il bersaglio a compiere un'azione non sicura (cliccare un link, rivelare credenziali, trasferire denaro, scaricare un malware).

1. VETTORE DI ATTACCO PRIMARIO: PHISHING SU EMAIL

Le email sono il vettore più efficace per attacchi mirati (spear phishing). L'analisi ha rivelato numerosi indirizzi email pubblici, alcuni dei quali sono critici.

1.1. Target: A&A Management Group (Travis Kelce)

Email	Ruolo/Scopo	Rischio
info@aamanagementgroup.com	Contatto principale dell'azienda di gestione	ALTISSIMO
hello@aamanagementgroup.com	Contatto generico (scoperto da DNS)	ALTO
info@aaamanagementservice.com	Amministrazione fondi (Seychelles)	ALTO
filler@godaddy.com	Email placeholder su sito non sicuro	BASSO

Scenario di Attacco 1: Spear Phishing ai Gestori di Travis Kelce

- Bersaglio: Il team di A&A Management Group (destinatario: info@aamanagementgroup.com).
- Pretesto: Una falsa richiesta di sponsorizzazione o di partnership da parte di un'azienda apparentemente legittima (es. "Nike", "State Farm", "Pepsi").
- Vettore: Email che sembra provenire da un dominio simile a quello di un vero partner (nike-corp.com invece di nike.com).
- Contenuto dell'Email:
Oggetto: Proposta di Collaborazione - Travis Kelce
Gentile Team di A&A Management,
Siamo interessati a discutere una partnership esclusiva con Travis Kelce per la nostra prossima campagna pubblicitaria. Abbiamo già lavorato con altri atleti di alto profilo e riteniamo che Travis sia il volto ideale per il nostro brand.

Per favore, trovate in allegato la nostra proposta preliminare e il contratto di NDA da firmare prima di procedere. Vi chiediamo di esaminarlo con attenzione. Cordiali saluti,

[Nome falso], Direttore Marketing

[Azienda fittizia]

- Allegato malevolo: Il file PDF della "proposta" contiene un macro che, una volta attivato, scarica un malware o un keylogger. In alternativa, il link nel corpo dell'email reindirizza a una pagina di login falsa di Google (per rubare le credenziali di Gmail).
- Esito: Se un membro del team di A&A Management apre il file o clicca sul link, l'attaccante può ottenere accesso alle email aziendali, a contratti, a informazioni sui clienti e persino a credenziali bancarie.

1.2. Target: Taylor Swift Store (E-Commerce)

Email	Ruolo/Scopo	Rischio
taylorswift@umgstores.com	Supporto clienti del negozio	ALTO
privacy@taylorswift.com	Richieste privacy	MEDIO-ALTO
webmaster@taylorswift.com	Gestione tecnica del sito	MEDIO

Scenario di Attacco 2: Phishing ai Clienti dello Store

- Bersaglio: I milioni di fan che hanno acquistato dallo store ufficiale.
- Pretesto: Un falso avviso di problema con un ordine (es. "Il tuo pacco è stato bloccato", "Rimborso da confermare").
- Vettore: Email che sembra provenire da store.taylorswift.com o umgstores.com, con un dominio simile come store-taylorswift.com o umgstores-support.com.
- Contenuto dell'Email:
Oggetto: Importante: Problema con il tuo ordine #TS-123456
Caro Cliente,
Siamo spiacenti di informarti che c'è stato un problema con il tuo ordine recente. Il tuo pacco è stato bloccato alla dogana e necessita di una verifica della tua identità.
Per favore, clicca sul link qui sotto per confermare il tuo indirizzo di spedizione e

i dettagli della tua carta di credito per sbloccare la spedizione:

[Link al sito falso di phishing]

Ci scusiamo per l'inconveniente.

Il Team di Taylor Swift Store

- Pagina di Phishing: Il link reindirizza a una copia identica del sito di login dello store o di un gateway di pagamento falso. I fan, abituati a comprare online, potrebbero inserire i loro dati di carta di credito, pensando di risolvere un problema.
 - Esito: Furto di dati di pagamento (numeri di carte di credito, CVV, indirizzi di fatturazione). Questi dati possono poi essere rivenduti o utilizzati per acquisti fraudolenti.
-

2. VETTORE SECONDARIO: PHISHING E SOCIAL ENGINEERING TRAMITE SOCIAL MEDIA

I social media sono il terreno di caccia ideale per attacchi di ingegneria sociale diretti ai dipendenti o ai fan.

2.1. Target: Dipendenti di A&A Management (LinkedIn)

- Bersaglio: Dipendenti di A&A Management Group visibili su LinkedIn (es. Aaron Eanes, Andrei Eanes).
- Pretesto: Un messaggio su LinkedIn da un "reclutatore" o un "investitore" che sembra legittimo.
- Vettore: Messaggio diretto su LinkedIn o email via LinkedIn.
- Tecnica: L'attaccante si finge un headhunter di un'azienda concorrente e offre un'opportunità di lavoro. Per "verificare" le competenze, chiede al dipendente di condividere un documento o di cliccare su un link a un portale di "assessment".
- Esito: Il link conduce a un sito malevolo che ruba le credenziali di LinkedIn o di altri account. Una volta compromesso l'account di un dipendente, l'attaccante può usarlo per inviare messaggi di phishing ad altri dipendenti o persino a Travis Kelce stesso.

2.2. Target: Fan e Seguaci di Taylor Swift (Instagram/Facebook/TikTok)

- Bersaglio: Milioni di fan che seguono Taylor Swift sui social.
- Pretesto: Un falso concorso o giveaway. "Taylor Swift ti ha scelto per vincere un biglietto per il tour!".

- **Vettore:** Commenti o messaggi diretti sui post di Taylor Swift, o annunci sponsorizzati falsi su Instagram e Facebook.
 - **Contenuto:**
"Ciao! Sono il team di Taylor Swift. Congratulazioni! Sei stato selezionato come vincitore del nostro giveaway. Per ricevere il tuo premio, clicca sul link qui sotto e inserisci i tuoi dati."
 - **Esito:** Furto di dati personali (nome, indirizzo, data di nascita) e di dati di pagamento (per coprire le "spese di spedizione" del premio). Gli account dei fan compromessi possono essere utilizzati per diffondere ulteriori truffe.
-

3. VETTORE TERZIARIO: VISHING (PHISHING TELEFONICO)

I numeri di telefono sono un vettore meno comune ma molto efficace se usato bene.

- **Target:** Team di A&A Management o dello Store.
 - **Pretesto:** Una chiamata da parte di un "fornitore" o "partner" che richiede un pagamento urgente o la conferma di dati.
 - **Vettore:** Chiamata telefonica diretta a uno dei numeri esposti (es. il numero di A&A Management su ZoomInfo, o i numeri di contatto dello store).
 - **Tecnica:** L'attaccante, impersonando un manager di un'azienda partner (es. un promoter), chiama il team di gestione e, con una scusa (es. "abbiamo un problema con il bonifico per l'evento di Travis"), chiede di confermare i dati bancari o di effettuare un pagamento urgente a un conto diverso.
 - **Esito:** Frode finanziaria (Business Email Compromise - BEC, versione telefonica).
-

4. TABELLA RIEPILOGATIVA: VULNERABILITÀ E PRIORITÀ

Vettore	Target	Esempio di Attacco	Priorità di Mitigazione
Email	Team A&A Management	Spear phishing con allegato malevolo	CRITICA

(proposta di partnership)			
Email	Clienti dello Store	Phishing per problemi con ordini (furto di carte di credito)	ALTA
Social Media (LinkedIn)	Dipendenti A&A Management	Messaggio da falso reclutatore (rubare credenziali)	ALTA
Social Media (Instagram, ecc.)	Fan di Taylor Swift	Falsi giveaway/concorsi (furto di dati personali)	MEDIO-ALTA
Telefono (Vishing)	Team A&A Management / Store	Chiamata da falso fornitore per richiedere pagamento	MEDIO
Siti Web	Fan che visitano siti falsi	Siti clone dello store (phishing)	ALTA

5. RACCOMANDAZIONI DI MITIGAZIONE (SPECIFICHE PER SOCIAL ENGINEERING)

- Formazione del Personale (A&A Management, UMG, Staff di Taylor Swift):
 - Condurre sessioni di security awareness dedicate a:

- Riconoscimento di email di phishing (verificare il dominio del mittente, non cliccare su link sospetti, non aprire allegati non richiesti).
 - Verifica dell'identità di chi chiama (richiamare il mittente tramite canali ufficiali).
 - Uso di MFA (Autenticazione a più fattori) su tutti gli account (email, social, cloud).
 - Simulare attacchi di phishing (red teaming) per testare la prontezza del personale.
2. Protezione dell'Email (Tutti i Domini):
- Implementare rigorosamente DMARC, SPF, e DKIM per prevenire lo spoofing del dominio (taylorswift.com, aamanagementgroup.com, chiefs.com).
 - Utilizzare filtri anti-phishing e anti-malware di livello enterprise (es. Microsoft Defender, Google Workspace Advanced Protection).
3. Gestione dei Social Media:
- Limitare l'esposizione delle informazioni personali dei dipendenti su LinkedIn e altri social.
 - Monitorare attivamente la comparsa di account falsi che impersonano Taylor Swift, Travis Kelce, A&A Management o lo Store. Segnarli alle piattaforme.
 - Utilizzare strumenti di brand protection per monitorare l'uso di nomi e loghi in domini e account sospetti.
4. Protezione dei Clienti/Fan:
- Inviare comunicazioni regolari ai fan per avvisarli di potenziali truffe (es. "Attenzione: ci sono falsi giveaway su Instagram. Il nostro unico canale ufficiale è...").
 - Non chiedere mai dati sensibili (password, numeri di carte di credito) via email. I clienti devono essere reindirizzati al sito ufficiale per qualsiasi operazione.
5. Protezione Aggiuntiva per le Email dello Store:
- Limitare l'uso dell'email taylorswift@umgstores.com a comunicazioni strettamente necessarie.
 - Utilizzare un sistema di ticket (es. Zendesk) per il supporto clienti, in modo che le comunicazioni siano tracciate e verificate.
-

Conclusione sulla Valutazione del Rischio di Social Engineering

L'ecosistema digitale analizzato presenta vulnerabilità critiche a livello umano. La visibilità pubblica dei personaggi (Taylor Swift, Travis Kelce) e la presenza di email aziendali e personali esposte creano un bersaglio perfetto per attacchi di social engineering.

Un attaccante potrebbe facilmente:

1. Ingannare un dipendente di A&A Management per ottenere l'accesso a informazioni riservate.
2. Rubare dati finanziari dai fan dello store tramite phishing mirato.
3. Compromettere account social di alto profilo per diffondere disinformazione o truffe.

La principale difesa contro questi attacchi è la consapevolezza e la formazione. La tecnologia (filtri anti-phishing, MFA) è un supporto fondamentale, ma non sostituisce la capacità delle persone di riconoscere e segnalare tentativi di frode.